OpenHarmony-Audit-Agent 工具性能说明

对应题目一交付件 5。当前提供规划模块的实测工程数据、测量方法和完整任务复测入口。大规模 OpenHarmony 源码审计的端到端耗时与内存尚无实测，因此本说明书还不能独立满足该交付件的完整数据要求。

1. 数据来源与范围

CodeQL-AI 来源 commit 为 51dbf412f440f723746087588665646c0edadddd。其 docs/evaluation-design.md 规定了建库时间、查询时间、单告警中位数、P95、超时数和成功率，但没有填写实验结果；docs/refined.md 描述局部符号分析方法，也未提供规模与内存实测。环境表中的 Apple M2 Pro / 16GB 属于示例，不能作为工具内存占用。

本说明的数值来自本机运行主体规划模块的真实测量。输入为合成任务元数据，不包含源码文件。没有调用模型、CodeQL、符号执行或设备。规划数据只能说明任务分片开销，不能推断大规模漏洞扫描的时间、吞吐或准确性。

2. 测试环境与方法

• 操作系统：Windows-11-10.0.26200-SP0；架构：AMD64。

• 处理器报告：Intel64 Family 6 Model 197 Stepping 2, GenuineIntel；逻辑 CPU：16。

• 物理内存总量：31.50 GiB；这属于主机配置。

• Python：3.12.14；工作流配置：config/workflow.audit.example.json；并发分片目标为 2 个 worker。

• 输入规模：1,000、10,000、50,000 个合成 analysis unit。权重按 i mod 7 + 1 生成，输入规格哈希保存在原始记录中。

• 每个进程重复规划 20 次，每种规模启动 3 个独立进程。脚本内部统计规划时间，外部采样间隔为 20 ms。

内存使用同一时刻父进程及其存活子进程 RSS 之和的最大采样值；可能重复计入共享页面，也可能漏掉短暂峰值或短生命周期子进程。监控进程与远端模型内存不在统计范围内。墙钟时间包含进程启动和输入构造，单次规划时间只统计 build_plan 循环。所有输出原始记录见 reports/performance/。

3. 规划模块实测结果

合成单元数	每进程规划次数	单次规划秒数（3 次运行中位数）	整个进程秒数（中位数）	最大观测 RSS（MiB）
1,000	20	0.000673	0.134	20.06
10,000	20	0.009920	0.320	30.22
50,000	20	0.096826	2.104	68.70

以上 9 个进程均正常退出。source_files_scanned、model_calls、codeql_calls 均为 0。未报告规划 P95：每组仅 3 个进程，样本不足以代表尾部性能。不同环境和任务内容会改变结果，不能按单元数量线性外推源码审计耗时。

4. 完整审计需要补测的数据

指标	当前状态	正式记录内容
源码规模与覆盖	未实测	版本清单、文件数、LOC、实际读取/审计单元、排除项
主体端到端审计耗时	未实测	同一目标从启动到报告的墙钟时间，含失败与重试
主体进程树内存	未实测	采样 RSS 及口径，远端模型资源另列
可选 CodeQL 建库与查询	未实测	命令、规则与版本、冷/热缓存、阶段耗时、内存
辅助验证开销	未实测	每次调用时间、有效完成数、超时和失败、P50/P95
模型使用量	未实测	模型版本、请求数、输入/输出 token、重试与费用口径
主体与增强版对照	未实测	相同快照、预算与复核标准下比较增量成本与收益

5. 可复现测量入口

安装基础包和可选 benchmark 依赖后，从源码根目录执行。使用已有、配置正确的真实任务时，最后一条命令会运行实际 Agent，需具备模型认证与配额。

```
python -m pip install -e ".[benchmark]"
python scripts/measure_command.py --output reports/planner-measurement.json --scope synthetic-planner-only --snapshot synthetic-v1 -- python scripts/benchmark_planner.py --units 50000 --iterations 20
python scripts/measure_command.py --output reports/audit-measurement.json --scope source-audit --snapshot YOUR_COMMIT -- python -m openharmony_audit workflow run --run-root reports/run-data
```

measure_command.py 使用参数数组启动子进程，不经 shell 拼接。JSON 记录墙钟时间、峰值采样 RSS、采样间隔、退出码及硬件信息；stdout.log 保存命令输出。输入命令不能包含明文密钥，日志应在交付前检查。重跑应使用独立运行目录，避免终态跳过导致误把恢复检查时间当完整审计时间。

可选静态建库、查询和辅助调用应分别使用同一测量入口。总墙钟时间从完整任务起止计算；并行任务时间不能简单累加为端到端时间。完成率分母包含失败与超时样本，耗尽预算的运行单独标识。

6. 已有机制与局限

主体按单元分片，保留检查点并限定角色调查范围。CodeQL-AI 聚焦需要复核的函数或路径，目标是控制额外成本；实际收益需测量。局部符号执行仍可能出现状态膨胀。

源码中的 timeout 默认值属于配置，不是完成耗时保证。来源 path_executor.py 虽有 timeout=120 参数，但探索逻辑主要使用 LengthLimiter(max_length=2000)，未实现对应墙钟超时；不能写成“每条路径 120 秒内完成”。LengthLimiter 也不是总状态数或内存上限。

最终提交交付件 5 前，需要补入大规模目标的快照、规模、任务命令、硬件配置、耗时与内存原始记录。当前说明保留这一缺口，未以源码行数估算或合成元数据代替扫描性能。

7. 来源

• 官方题目：https://cpipc.acge.org.cn/cw/hp/2c90800c8093eef401809d33b36f0652

• 原工具评估设计：https://github.com/Binnnn-Lab/CodeQL-AI/blob/51dbf412f440f7237460875886656 46c0edadddd/docs/evaluation-design.md

• 原工具方法说明：https://github.com/Binnnn-Lab/CodeQL-AI/blob/51dbf412f440f7237460875886656 46c0edadddd/docs/refined.md

• 复现源码：scripts/measure_command.py、scripts/benchmark_planner.py；原始记录：reports/performance/。